PURPOSE CAPITAL
Guiding Capital with Purpose

PROCEDURE · COMPLIANCE

# Incident and Corrective Action Plan Management Procedure

Version **0.9** DRAFT

| | |
|---|---|
| Owner | Chief Executive Officer |
| Next review | 12 months after adoption |
| Confidentiality | Internal |

DRAFT

**Purpose Capital S.A.**
Rue Joseph Essono Balla, Elig-Essono, Yaoundé (Cameroun)

Courtesy translation — the French version prevails.
Issued on 3 November 2026

# Document control sheet

Courtesy translation — the French version prevails.

| | | | |
|---|---|---|---|
| **Version** | 0.9 — Draft | | |
| **Title** | Incident and Corrective Action Plan Management Procedure | | |
| **Type · domain** | Procedure · Compliance | **Confidentiality** | Internal |
| **Owner** | Chief Executive Officer | | |
| **Distribution** | All Staff Members | | |
| **Effective date** | On adoption | **Next review** | 12 months after adoption |

## APPROVAL WORKFLOW

| Step | Function | Electronic sign-off | Handwritten signature |
|---|---|---|---|
| Drafting | Head of Compliance and Internal Control (RCCI) | | |
| Review | Head of Compliance and Internal Control (RCCI) | | Date and signature |
| Approval | Chief Executive Officer | | Date and signature |

## REVISION HISTORY

| Version | Date | Purpose | By |
|---|---|---|---|
| 0.9 | 20 October 2026 | Initial draft | Compliance Officer |

## REFERENCE TEXTS

| | |
|---|---|
| COSUMAF General Regulation of 23 May 2023<br>Official text · cosumaf.org | Risk-based approach, risk map and annual internal control report submitted before 31 March (Art. 5); compliance and internal control function (Art. 13); retention of documents for ten years (Art. 105) |
| Regulation No. 01/22/CEMAC/UMAC/CM/COSUMAF of 21 July 2022<br>Official page · cosumaf.org | Organisation and obligations of intermediaries on the regional financial market, including cooperation with COSUMAF |
| Regulation No. 02/24/CEMAC/UMAC/CM of 20 December 2024<br>Overview · droitmediasfinance.com | Suspicious transaction reports to ANIF, confidentiality of the report and prohibition of tipping off |
| Law No. 2024/017 of 23 December 2024 on the protection of personal data in Cameroon<br>Overview · droitmediasfinance.com | Data security and notification of personal data breaches to the data protection authority and to the data subjects |
| Cameroon Labour Code (Law No. 92/007 of 14 August 1992)<br>Official text · ilo.org | Employer's disciplinary authority, within the limits of which the commitment not to sanction an error reported in good faith is made |
| Basel Committee — Revisions to the Principles for the Sound Management of Operational Risk (2021)<br>Official text · bis.org | International good practice: collection of incidents and losses, root-cause analysis, reporting to management and the board |
| COSO — Internal Control — Integrated Framework (2013) | International framework: monitoring activities, evaluation and communication of internal control deficiencies (principles 16 and 17) |

DRAFT

| | |
|---|---|
| ISO 9001 — Quality management systems, control of documented information (§ 7.5) | International good practice: same standard, § 10.2 (nonconformity and corrective action) and § 10.3 (continual improvement) |
| ISO 31000 — Risk management — Guidelines | International good practice: monitoring, review and improvement of the risk management framework |

DRAFT

# Contents


**I. General provisions**

Article 1 — Purpose
Article 2 — Scope
Article 3 — Definitions
Article 4 — Principles
Article 5 — Relationship with other documents

**II. Roles**

Article 6 — Who does what
Article 7 — Where the RCCI or the Chief Executive Officer is implicated

**III. Detecting and reporting**

Article 8 — Where incidents and findings come from
Article 9 — Reporting an incident
Article 10 — A reporting culture
Article 11 — Recording findings

**IV. Classifying and responding**

Article 12 — Immediate measures
Article 13 — Severity scale
Article 14 — Escalation
Article 15 — Notifications to authorities and third parties
Article 16 — Affected clients

**V. Analysing and correcting**

Article 17 — Root-cause analysis
Article 18 — Action plan
Article 19 — Follow-up and extension of deadlines
Article 20 — Closure and verification of effectiveness

**VI. Register and reporting**

Article 21 — Single register
Article 22 — Monthly review
Article 23 — Quarterly report to the Board of Directors
Article 24 — Annual summary

**VII. Learning lessons**

Article 25 — Updating documents
Article 26 — Training and sharing
Article 27 — Indicators

**VIII. Final provisions**

Article 28 — Control
Article 29 — Entry into force

**Appendices**

Appendix “Incident report form” — Incident reporting form
Appendix “Severity and escalation” — Severity and escalation grid
Appendix “Incident register” — Register of incidents and action plans
Appendix “Root-cause analysis” — Root-cause analysis and action plan form
Appendix “Quarterly Board report” — Quarterly report to the Board of Directors on incidents and action plans


DRAFT

# Title I — General provisions

### Article 1 — Purpose

This procedure sets out how Purpose Capital S.A. (the "Company") learns from its mistakes: how it identifies incidents and weaknesses in its organisation, corrects them, checks that the correction works and draws lasting lessons from them.

It is the engine of the Company's continuous improvement. A well-handled incident costs once; a badly handled incident comes back. The procedure details Article 28 of the Risk Management Policy for incidents, and Article 17 of the Internal Control and Compliance Charter for the follow-up of recommendations. It does not replace them.

### Article 2 — Scope

The procedure applies:

- to all Staff Members, including the Chief Executive Officer, and to directors for facts of which they become aware;
- to service providers, under the conditions set out in their contract, in particular the IT service provider;
- to all incidents, whatever their cause, and to all findings from internal and external controls, whatever their origin.

### Article 3 — Definitions

- **Incident**: an event that caused, or could have caused, a loss, an error, an interruption or a breach. It may be:
  - **operational**: input or execution error, wrongly transmitted order, erroneous payment, reconciliation difference, lost document;
  - **compliance-related**: breach of regulation or of an internal procedure, late submission to COSUMAF, incomplete client file;
  - **IT or cybersecurity**: outage, intrusion, successful phishing, loss or leak of data;
  - **affecting a client**: any incident that affects a client, their assets, their orders or their data.
- **Near miss**: an error detected and stopped before it had any effect. It is reported as an incident, because it reveals the same weakness.
- **Finding**: a weakness identified by a control: ongoing control by the RCCI, annual independent review, statutory auditors, COSUMAF inspection or request, analysis of complaints, business continuity plan exercise, assessment of a service provider.
- **Root cause**: the underlying reason why the incident occurred or the finding exists; if it is removed, the problem does not recur.
- **Corrective action**: an action that removes the root cause of an incident or finding, so that it does not recur.
- **Preventive action**: an action that removes the cause of a problem that has not yet occurred, but which the analysis has revealed elsewhere.
- **Action plan**: all the actions decided for an incident or a finding; each action has an owner, a deadline and an expected evidence of completion.

DRAFT

- **Repeat incident**: an incident of the same nature, or with the same root cause, as an incident that occurred in the previous twelve months.

### Article 4 — Principles

1. **Everything is reported**: an incident, however small, even if avoided or corrected, is reported. What is not reported cannot be corrected.
2. **The client first**: we protect the client and correct before trying to explain.
3. **We look for a cause, not a culprit**: the analysis targets the organisation, the tools and the rules, not the person.
4. **A single register**: incidents and findings from all sources are followed up in a single register, using the same severity scale.
5. **An action is closed only on evidence**: the RCCI checks completion, then effectiveness.
6. **Every lesson changes something**: a procedure, a control, a tool or a training session.
7. **Proportionality**: the analysis effort is proportionate to severity; an isolated minor incident does not require an investigation.

### Article 5 — Relationship with other documents

This procedure organises the common workflow; the rules specific to each subject remain in their own document.

| Subject | Prevailing document |
|---|---|
| Risk appetite, limits, risk map | Risk Management Policy |
| Control plan, rating of findings, independent review | Internal Control and Compliance Charter |
| Suspicion of money laundering, asset freezing | AML/CFT Policy (Anti-Money Laundering and Counter-Terrorist Financing Policy) |
| IT security incident, data breach | Information Systems Security Policy |
| Crisis and business interruption | Business Continuity Plan |
| Notifications to COSUMAF | Regulatory Reporting Procedure |
| Differences on client assets | Client Asset Segregation and Reconciliation Procedure |
| Complaints and client redress | Complaints Handling Procedure |
| Failure of a service provider | Outsourcing Policy |
| Whistleblowing | Code of Conduct, Article 47 |

DRAFT

# Title II — Roles

## Article 6 — Who does what

| Function | Role |
|---|---|
| Every Staff Member | Takes the immediate measures within their reach; reports the incident on the same day; takes part in the root-cause analysis; carries out the actions for which they are responsible |
| Head or manager of the department concerned | Checks the immediate measures; proposes the action plan for their area; reports on the progress of actions |
| RCCI | Records and classifies; triggers escalation; conducts or has conducted the root-cause analysis; keeps the single register; checks the completion and effectiveness of actions; reports |
| Chief Executive Officer | Decides on measures and resources for significant and major incidents; approves action plans; decides on notifications to authorities and on redress; chairs the monthly review |
| Chairman of the Board of Directors | Is informed of significant and major incidents; informs the Board; handles incidents implicating the Chief Executive Officer |
| Board of Directors | Examines the report in Appendix “Quarterly Board report” each quarter; decides on the follow-up of major incidents where warranted |
| IT service provider | Reports without delay any incident on the systems it manages; takes part in the analysis; carries out the actions provided for in its contract |

## Article 7 — Where the RCCI or the Chief Executive Officer is implicated

No one classifies, analyses or closes an incident in which they are personally implicated.

- If the incident implicates the RCCI, or if the RCCI is responsible for an action, the Chief Executive Officer classifies the incident or checks the action.
- If the incident implicates the Chief Executive Officer, the RCCI informs the Chairman of the Board of Directors directly, who decides on the follow-up.

DRAFT

# Title III — Detecting and reporting

### Article 8 — Where incidents and findings come from

The single register is fed by:

- **incidents reported** by Staff Members and service providers;
- **findings from ongoing controls** by the RCCI (control sheets of the Internal Control Charter, Appendix "Control sheet");
- **recommendations of the annual independent review** and of the **statutory auditors**;
- **findings and injunctions from COSUMAF**, following an inspection, a request or a submission;
- the **quarterly analysis of complaints** (Complaints Handling Procedure, Article 16);
- **lessons learned** from the Business Continuity Plan, after a crisis or an exercise;
- **notices from BVMAC and the central securities depository** reporting an anomaly attributable to the Company.

### Article 9 — Reporting an incident

Any Staff Member who discovers an incident reports it to the RCCI **on the day it is discovered, and at the latest within 24 hours**, using the form in Appendix "Incident report form". An email covering the headings of the form is sufficient at first.

Where the incident is ongoing or appears serious (client affected, fraud, cyberattack, client assets at stake), they first alert the RCCI and the Chief Executive Officer **by telephone, immediately**, then complete the form.

Two special cases:

- an **IT security incident** is also reported immediately to the IT focal point, in accordance with Article 20 of the Information Systems Security Policy; the form of that policy may stand in for the form in Appendix "Incident report form";
- a **suspicion of money laundering or terrorist financing** is not reported on the form in Appendix "Incident report form". It is reported to the AML/CFT officer in accordance with Article 23 of the AML/CFT Policy. The single register keeps no named record of it; only a failure of the framework (control not performed, alert not handled) is entered there, without mention of the suspicion.

The Staff Member reports what they know when they know it. They do not wait until they have understood everything, or until they have corrected it.

### Article 10 — A reporting culture

A Staff Member who spontaneously and in good faith reports an error they have made **is not sanctioned for that error**, in accordance with Article 30 of the Risk Management Policy. Only the following constitute misconduct within the meaning of Article 49 of the Code of Conduct:

- concealing an incident or deliberately delaying its reporting;
- destroying or altering evidence;
- intentional misconduct, fraud, or serious negligence repeated despite reminders.

DRAFT

The Chief Executive Officer and the RCCI set the example by reporting their own errors. A Staff Member who is reluctant to report a fact implicating a superior, or who wishes to remain anonymous, uses the whistleblowing procedure in Article 47 of the Code of Conduct.

### Article 11 — Recording findings

The RCCI enters in the single register each finding and each recommendation:

- **as soon as the control sheet is finalised**, for their own controls;
- **within five business days** of receipt of the final report, for the independent review, the statutory auditors and COSUMAF.

A report containing several recommendations gives one line per recommendation. Findings are rated in accordance with Article 16 of the Internal Control Charter; a COSUMAF finding or injunction is rated at least "significant".

DRAFT

# Title IV — Classifying and responding

### Article 12 — Immediate measures

Before any analysis, the person who discovers the incident and their manager:

1. **stop** whatever may make the situation worse: order suspended, payment blocked, access cut off;
2. **protect clients**: a client never bears alone the consequences of an error by the Company;
3. **preserve evidence**: orders, emails, logs, screenshots; nothing is deleted or "cleaned up";
4. **correct** what can be corrected straight away, with a second pair of eyes;
5. **note** the time and nature of each measure on the form in Appendix “Incident report form”.

Where the incident interrupts an essential activity, the Chief Executive Officer assesses whether to trigger the Business Continuity Plan.

### Article 13 — Severity scale

The RCCI classifies the incident **at the latest on the business day following the report**, and immediately if it appears major. They apply the grid in Appendix “Severity and escalation”.

| Severity | Criteria (one is enough) |
|---|---|
| Minor | No client affected, or error corrected the same day with no effect on the client; loss below FCFA 1,000,000; departure from an internal procedure without regulatory breach; near miss without serious potential |
| Significant | One client affected (execution error, late payment, inaccurate information); loss from FCFA 1,000,000 to less than FCFA 10,000,000; regulatory breach, for example late submission to COSUMAF or incomplete client file; interruption of a service for more than half a day; data compromised without proven disclosure; near miss that would have been major; repeated minor incident |
| Major | Loss of FCFA 10,000,000 or more, or loss bringing own funds closer to their alert threshold; loss for several clients or unexplained difference on client assets; proven fraud, internal or external; successful cyberattack or breach of client data; interruption of services to clients for more than one business day; breach liable to a COSUMAF sanction or to call the licence into question; public criticism of the Company; incident involving a senior manager; repeated significant incident |

A significant or major incident is a "significant incident" within the meaning of Article 28 of the Risk Management Policy. Where in doubt between two levels, the RCCI chooses the higher one; they may lower the rating once the facts are established, recording this in the register.

### Article 14 — Escalation

| Severity | Who is informed | Time limit | By what means |
|---|---|---|---|
| Minor | Manager of the department concerned | On recording | Register; item at the monthly review |
| Significant | Chief Executive Officer, then Chairman of the Board of Directors | Within 24 hours of discovery | Email from the RCCI summarising the facts, the measures taken and the risks |
| Major | Chief Executive Officer and Chairman of the Board of Directors | Immediately by telephone; written note the same day | Telephone, then note from the RCCI |

DRAFT

| Severity | Who is informed | Time limit | By what means |
|---|---|---|---|
| Major | Directors | Within 5 business days | Note from the Chief Executive Officer; Board meeting if the Chairman considers it necessary |

These time limits reflect Article 27 of the Risk Management Policy. Each communication is dated in the register.

### Article 15 — Notifications to authorities and third parties

For each significant or major incident, the RCCI examines whether an authority or a third party must be informed, using Appendix “Notifiable events” of the Regulatory Reporting Procedure. The Chief Executive Officer decides or, if implicated, the Chairman of the Board of Directors. The RCCI prepares the notification and keeps evidence of it.

| Recipient | When | Applicable rule |
|---|---|---|
| COSUMAF | Significant incident affecting clients or the market: difference on client assets, fraud, cyberattack, prolonged interruption; major dispute | Without delay, written confirmation within 48 hours (Regulatory Reporting Procedure, Article 13) |
| ANIF | Suspicion of money laundering or terrorist financing; asset freezing | By the AML/CFT officer alone, in accordance with the AML/CFT Policy; never through this workflow |
| Data protection authority and data subjects | Personal data breach | Within the legal time limit, in accordance with the Information Systems Security Policy (Article 20) |
| BVMAC, central securities depository | Settlement failure, member incident | In accordance with their rules |
| Insurer | Loss covered by the professional liability or fraud insurance | Within the time limit set in the contract |

Where in doubt, the Company informs COSUMAF: an unnecessary notification costs nothing, a missed notification may cost the licence.

### Article 16 — Affected clients

Where a client is affected, the Company informs them in writing, without waiting for a complaint, of what happened, what has been corrected and what is offered to them.

Redress follows Article 11 of the Complaints Handling Procedure, and decision-making powers follow its Article 13. Redress does not wait for the end of the root-cause analysis. If the client disputes it, their request is handled as a complaint.

DRAFT

# Title V — Analysing and correcting

### Article 17 — Root-cause analysis

A root-cause analysis is mandatory for:

- every significant or major incident;
- every repeat incident, even if minor;
- every finding rated major or significant.

It is conducted by the RCCI with the persons concerned, in a short meeting. It is completed, together with the action plan, **within 5 business days** for a major incident or finding, and **within 10 business days** for a significant incident or finding.

The method is the **"five whys"**: start from the observed fact and ask "why?" until reaching a cause on which the Company can act, usually after three to five questions. Each answer is based on a verified fact. The analysis stops at a cause relating to organisation, tools or rules, not at "human error": if a person made a mistake, the question is why the framework did not stop it.

The form in Appendix “Root-cause analysis” is used. It classifies the root cause in one of the following categories: missing or inadequate procedure; missing or ineffective control; tool or system; skills or information; workload or organisation; service provider; external event.

### Article 18 — Action plan

The action plan includes corrective actions and, where the analysis shows it, preventive actions on other activities exposed to the same cause. Each action specifies:

- **what**: a concrete and verifiable action ("add a check that the account number matches before transmission", not "be more vigilant");
- **who**: an owner designated by their function;
- **when**: a deadline;
- **what evidence**: the document that will show the action has been completed (revised procedure, screenshot of the configuration, attendance list, control sheet).

Deadlines follow Article 16 of the Internal Control Charter, which also applies to incidents:

| Severity | Action plan | Correction |
|---|---|---|
| Major | Within 5 business days | Within 1 month |
| Significant | Within 10 business days | Within 3 months |
| Minor | If necessary | Within 6 months |

The Chief Executive Officer approves the action plan for significant and major incidents and findings, and allocates the necessary resources. For a COSUMAF finding, the deadline it sets prevails if it is shorter.

### Article 19 — Follow-up and extension of deadlines

The owner of each action reports to the RCCI at the deadline, or earlier if they expect a delay.

DRAFT

A deadline may be extended only once, by a reasoned decision of the Chief Executive Officer recorded in the register. The extension of an action linked to a major incident or finding, or to a COSUMAF finding, is brought to the attention of the Chairman of the Board of Directors.

Overdue actions are examined at each monthly review; those more than three months overdue are presented to the Board of Directors, in accordance with Article 17 of the Internal Control Charter.

### Article 20 — Closure and verification of effectiveness

An action is **completed** when its owner has provided the expected evidence and the RCCI has checked it. The RCCI dates and signs off the closure in the register.

For significant and major incidents and findings, the RCCI also checks the **effectiveness** of the action, about three months after its completion: test on a sample of transactions, control included in the annual control plan, or confirmation that the incident has not recurred. If the action is not effective, the line is reopened and a new analysis is carried out.

An incident or finding is closed only when all its actions are completed and, where applicable, found effective.

DRAFT

# Title VI — Register and reporting

### Article 21 — Single register

The RCCI keeps the register of incidents and action plans using the template in Appendix "Incident register". This single register combines the incident register provided for by the Risk Management Policy and the recommendations follow-up table provided for by the Internal Control Charter.

- Each incident receives a number INC-year-number; each finding a number CST-year-number; each action a letter (INC-2027-004-a, -b…).
- The register is kept electronically; the RCCI writes to it, the Chief Executive Officer and the members of the risk and compliance committee consult it.
- Reporting forms, analysis forms and evidence of completion are filed in a folder per number.
- The register and the files are kept for **ten years** after closure, and made available to COSUMAF on request.

### Article 22 — Monthly review

The risk and compliance committee, the monthly management meeting provided for by the Risk Management Policy and the Internal Control Charter, devotes an item on its agenda to the register. The RCCI presents:

- new incidents and findings of the month, with their severity;
- the status of action plans: open, completed, overdue;
- actions to be closed and effectiveness checks;
- repeat incidents and lessons to be shared.

Decisions (approval of a plan, extension of a deadline, resources allocated) are recorded in the minutes of the meeting and carried over into the register.

### Article 23 — Quarterly report to the Board of Directors

Each quarter, the RCCI prepares the report in Appendix "Quarterly Board report", approved by the Chief Executive Officer. It is included in the quarterly dashboard presented to the Board of Directors (Internal Control Charter, Article 24; Risk Management Policy, Article 29). The Board may ask for explanations on any incident or any overdue action; its decisions are recorded in the minutes of the meeting.

### Article 24 — Annual summary

Each year, the RCCI summarises the register:

- in the **annual internal control report**, submitted to COSUMAF before 31 March, under the headings provided for by the outline in Appendix "Annual report outline" of the Internal Control Charter: findings and measures taken, incidents that affected clients, IT incidents, external controls and follow-up of recommendations;
- in the **update of the risk map** (Risk Management Policy, Article 9): each risk linked to a significant or major incident of the year is re-rated, and a risk revealed by an incident but missing from the risk map is added to it. A major incident triggers an update of the risk map without waiting for the annual review.

DRAFT

# Title VII — Learning lessons

### Article 25 — Updating documents

Where the analysis shows that a rule is missing, unclear or inadequate, the action plan provides for the amendment of the document concerned. The RCCI records the request in accordance with Article 8 of the Document Control Procedure, with the number of the incident or finding, and the deadline of the action applies to the publication of the revised document.

### Article 26 — Training and sharing

Where the cause lies in a lack of skills or information, the action plan provides for training or awareness-raising, included in the training plan in accordance with the Training Policy (Continuing Training, Competence and Good Repute Policy). The evidence of completion is the attendance list or the acknowledgement of reading.

Lessons useful to everyone are shared without naming anyone: through an item at the monthly review, through a short message to the Staff Members concerned, and each year during the mandatory training provided for by the Internal Control Charter (Article 21).

### Article 27 — Indicators

The RCCI monitors the following indicators, presented each quarter in the report in Appendix “Quarterly Board report”.

| Indicator | Target |
|---|---|
| Incidents reported, by severity | No target: a high number of reported minor incidents is a sign of a good reporting culture |
| Incidents reported within 24 hours | 100% |
| Root-cause analyses completed on time | 100% |
| Open actions | Trend monitoring |
| Overdue actions | 0 |
| Actions more than three months overdue | 0 |
| Repeat incidents | 0 |
| Actions found effective at verification | At least 90% |
| Incidents discovered by a third party (client, COSUMAF, BVMAC) before being reported internally | 0 |

DRAFT

# Title VIII — Final provisions

### Article 28 — Control

Each quarter, the RCCI checks that incidents known from other sources (complaints, reconciliations, IT logs, letters from authorities) are indeed in the register.

As the RCCI keeps the register and checks the actions themselves, the annual independent review (Internal Control Charter, Article 18) examines a sample of incidents and closed actions, and compliance with the time limits of this procedure.

### Article 29 — Entry into force

This procedure enters into force on the date of its approval, as shown on the document control sheet. It is reviewed every year.

DRAFT

APPENDIX "INCIDENT REPORT FORM" · INCIDENT AND CORRECTIVE ACTION PLAN MANAGEMENT PROCEDURE · FORM

# Incident reporting form

Version 0.9
Internal

**Completed by** Any Staff Member, then the RCCI **Frequency** On the day of discovery, at the latest within 24 hours

**Kept by** RCCI (incident file, single register) · ten years

Report what you know, even if you have not understood everything or the error has already been corrected. An error reported in good faith is not sanctioned; only concealment is. If the incident is ongoing or appears serious, first call the RCCI and the Chief Executive Officer.

**Never describe here a suspicion of money laundering or terrorist financing**: use the reporting form of the AML/CFT Policy (Anti-Money Laundering and Counter-Terrorist Financing Policy, Appendix "Suspicious transaction report").

REPORTING PERSON · FUNCTION _____ DATE AND TIME OF OCCURRENCE _____ DATE AND TIME OF DISCOVERY _____

Type: ☐ Operational ☐ Compliance ☐ IT or cybersecurity ☐ Client affected ☐ Service provider · ☐ Near miss

| | |
|---|---|
| **What happened (facts, without judgement)** | |
| **How the incident was discovered** | |
| **Activity, process, system or service provider concerned** | |
| **Clients concerned (number, accounts if known)** | |
| **Actual or estimated loss (FCFA)** | |
| **Immediate measures taken (what, by whom, at what time)** | |
| **Evidence preserved (orders, emails, logs, screenshots)** | |

DRAFT

| | |
|---|---|
| **Persons already alerted** | |

Date · signature of the reporting person

CLASSIFICATION BY THE RCCI (AT THE LATEST ON THE FOLLOWING BUSINESS DAY)

INC NO. _____ RECEIVED ON · AT _____ CLASSIFIED ON _____

Severity (Appendix "Severity and escalation"): ☐ Minor ☐ Significant ☐ Major · ☐ Repeat incident (same nature or same cause within 12 months)

Informed: ☐ Department manager ☐ Chief Executive Officer on ____ at ____ ☐ Chairman of the Board on ____ at ____ ☐ Directors on ____

Notifications examined: ☐ COSUMAF ☐ Data protection authority ☐ BVMAC or central securities depository ☐ Insurer ☐ None required · Decision of the Chief Executive Officer on ____

☐ Client(s) informed on ____ ☐ Redress under the Complaints Handling Procedure ☐ Business continuity plan triggered

Root-cause analysis (Appendix "Root-cause analysis"): ☐ Required, to be completed by ____ ☐ Not required (isolated minor incident)

COMMENTS _____

SIGN-OFF OF THE RCCI (OR OF THE CHIEF EXECUTIVE OFFICER IF THE RCCI IS IMPLICATED) _____

DRAFT

APPENDIX "SEVERITY AND ESCALATION" · INCIDENT AND CORRECTIVE ACTION PLAN MANAGEMENT PROCEDURE · MATRIX

# Severity and escalation grid

Version 0.9
Internal

**Completed by** RCCI **Frequency** At each classification of an incident or finding

**Kept by** RCCI · attached to each reporting form

**1. Severity.** One criterion is enough. Where in doubt, choose the higher level.

| Criterion | Minor | Significant | Major |
|---|---|---|---|
| Clients | No client affected, or error corrected the same day with no effect on the client | One client affected: execution error, late payment, inaccurate information | Loss for several clients; unexplained difference on client assets |
| Financial loss (Company or clients) | Less than FCFA 1,000,000 | From FCFA 1,000,000 to less than FCFA 10,000,000 | FCFA 10,000,000 or more, or loss bringing own funds closer to their alert threshold |
| Regulation | Departure from an internal procedure, without regulatory breach | Regulatory breach: late submission to COSUMAF, incomplete client file, mandatory control not performed | Breach liable to a COSUMAF sanction or to call the licence into question; proven fraud |
| Systems and continuity | Brief outage with no effect on clients | Interruption of a service for more than half a day; data compromised without proven disclosure | Successful cyberattack; breach of client data; interruption of services to clients for more than one business day |
| Reputation | No external effect | Dissatisfaction of a client or partner | Public criticism of the Company; incident involving a senior manager |
| Repetition and near miss | Near miss without serious potential | Repeated minor incident; near miss that would have been major | Repeated significant incident |

Control findings are rated in accordance with Article 16 of the Internal Control Charter (Internal Control and Compliance Charter); a COSUMAF finding or injunction is rated at least significant.

**2. Escalation and time limits.**

| Step | Minor | Significant | Major |
|---|---|---|---|
| Report to the RCCI | Same day, at the latest 24 hours | Same day, at the latest 24 hours | Immediately by telephone, then form the same day |
| Classification | Following business day | Following business day | Immediately |
| Chief Executive Officer | Monthly review | Within 24 hours | Immediately |
| Chairman of the Board of Directors | Quarterly report | Within 24 hours | Immediately; written note the same day |
| Directors | Quarterly report | Quarterly report | Within 5 business days |

DRAFT

| Step | Minor | Significant | Major |
|---|---|---|---|
| Notifications (COSUMAF, data protection authority, BVMAC, insurer) | No | To be examined | To be examined the same day |
| Root-cause analysis and action plan | Only if repeated | Within 10 business days | Within 5 business days |
| Approval of the plan | RCCI | Chief Executive Officer | Chief Executive Officer; Chairman of the Board informed |
| Correction | Within 6 months | Within 3 months | Within 1 month |
| Verification of effectiveness | No | About 3 months after completion | About 3 months after completion |

DRAFT

APPENDIX "INCIDENT REGISTER" · INCIDENT AND CORRECTIVE ACTION PLAN MANAGEMENT PROCEDURE · REGISTER

# Register of incidents and action plans

Version 0.9
Internal

**Completed by** RCCI **Frequency** Updated continuously; reviewed every month

**Kept by** RCCI · ten years after closure · presented to the risk and compliance committee and to the Board of Directors

One line per action. An incident or finding that calls for several actions takes up several lines bearing the same number (INC-2027-004-a, INC-2027-004-b). Origin: INC reported incident, CI internal control, RI independent review, CAC statutory auditors, COS COSUMAF, REC complaints analysis, PCA crisis or exercise, PRE service provider. Severity: Mi minor, S significant, Ma major. Status: O open, R overdue, Ré completed, E effective, RO reopened.

| No. | Origin · reference | Discovered on · reported on | Description | Severity | Clients · loss (FCFA) | Informed · notifications | Root cause | Action | Owner | Deadline (extension) | Expected evidence | Status | Completed on | Effectiveness checked on |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| | | | | | | | | | | | | | | |
| | | | | | | | | | | | | | | |
| | | | | | | | | | | | | | | |
| | | | | | | | | | | | | | | |
| | | | | | | | | | | | | | | |
| | | | | | | | | | | | | | | |
| | | | | | | | | | | | | | | |
| | | | | | | | | | | | | | | |

No suspicion of money laundering is entered in this register: it belongs in the confidential register of the AML/CFT officer.

OPEN ACTIONS

OF WHICH OVERDUE

OF WHICH MORE THAN 3 MONTHS OVERDUE (TO BE PRESENTED TO THE BOARD)

DRAFT

APPENDIX "ROOT-CAUSE ANALYSIS" · INCIDENT AND CORRECTIVE ACTION PLAN MANAGEMENT PROCEDURE · FORM

# Root-cause analysis and action plan form

Version 0.9
Internal

**Completed by** RCCI, with the persons concerned; plan approved by the Chief Executive Officer

**Frequency** For every significant or major incident or finding, and for every repeat incident

**Kept by** RCCI (incident or finding file) · ten years

| INC OR CST NO. | SEVERITY | ANALYSIS TO BE COMPLETED BY |
|---|---|---|
| | | |

| | |
|---|---|
| **Observed fact (what happened, in one sentence)** | |
| **Timeline (dates, times, persons, systems)** | |
| **Participants in the analysis** | |

**The five whys.** Start from the fact and ask "why?" until reaching a cause on which the Company can act. Each answer is based on a verified fact. Do not stop at "human error": ask why the framework did not stop the error.

| Question | Answer | Supporting fact |
|---|---|---|
| Why 1 | | |
| Why 2 | | |
| Why 3 | | |
| Why 4 | | |
| Why 5 | | |

**Example.** A buy order was executed on another client's account. *Why?* The client relationship officer entered a wrong account number. *Why?* Two clients have the same name and entry is made by name. *Why?* The tool lists clients by name, without showing the account number or the date of birth. *Why?* This case had not been anticipated in the configuration. **Root cause**: tool. **Actions**: show the account number and a second identifier at entry (corrective); check the other client selection screens (preventive); remind the team of the check that the signed order matches the transmitted order (corrective).

DRAFT

Root cause category: ☐ Missing or inadequate procedure ☐ Missing or ineffective control ☐ Tool or system ☐ Skills or information ☐ Workload or organisation ☐ Service provider ☐ External event

☐ Repeat incident: number of the previous incident _____ ☐ The same cause may affect other activities (plan a preventive action)

| Letter | Type | Concrete and verifiable action | Owner (function) | Deadline | Expected evidence |
|---|---|---|---|---|---|
| a | ☐ Corrective ☐ Preventive | | | | |
| b | ☐ Corrective ☐ Preventive | | | | |
| c | ☐ Corrective ☐ Preventive | | | | |

Lessons: ☐ Document to be amended (request under the Document Control Procedure): _____ ☐ Training or awareness-raising (Continuing Training, Competence and Good Repute Policy) ☐ Control to be added to the control plan ☐ Risk map to be reviewed ☐ Lesson to be shared with everyone

RCCI · date

Approval of the Chief Executive Officer · date

VERIFICATION OF EFFECTIVENESS (ABOUT 3 MONTHS AFTER COMPLETION)

METHOD: SAMPLE TESTED, CONTROL PERFORMED, NO RECURRENCE

RESULT

☐ Actions effective: incident or finding closed ☐ Not effective: line reopened and new analysis

DATE

SIGN-OFF OF THE RCCI (OR OF THE CHIEF EXECUTIVE OFFICER IF THE RCCI OWNS THE ACTION)

DRAFT

APPENDIX "QUARTERLY BOARD REPORT" · INCIDENT AND CORRECTIVE ACTION PLAN MANAGEMENT PROCEDURE · TEMPLATE

# Quarterly report to the Board of Directors on incidents and action plans

Version 0.9
Internal

**Completed by** RCCI; approved by the Chief Executive Officer **Frequency** Every quarter

**Kept by** RCCI · attached to the quarterly dashboard and to the Board minutes

| QUARTER | PREPARED ON | PRESENTED TO THE BOARD ON |
|---|---|---|
| | | |

## 1. Indicators

| Indicator | Quarter | Previous quarter | Target |
|---|---|---|---|
| Incidents reported: minor · significant · major | | | — |
| of which near misses | | | — |
| Incidents reported within 24 hours (%) | | | 100% |
| New findings: internal control · independent review · statutory auditors · COSUMAF | | | — |
| Root-cause analyses completed on time (%) | | | 100% |
| Open actions | | | — |
| Overdue actions | | | 0 |
| Actions more than 3 months overdue | | | 0 |
| Actions completed in the quarter | | | — |
| Actions found effective at verification (%) | | | At least 90% |
| Repeat incidents | | | 0 |
| Incidents discovered by a third party before being reported | | | 0 |
| Losses for the financial year: Company · redress paid to clients (FCFA) | | | — |

## 2. Significant and major incidents of the quarter

| No. | What happened | Severity | Root cause | Actions · status | Notified to |
|---|---|---|---|---|---|
| | | | | | |

DRAFT

| No. | What happened | Severity | Root cause | Actions · status | Notified to |
|---|---|---|---|---|---|
| | | | | | |
| | | | | | |

### 3. Actions more than three months overdue or extended

| No. | Action | Owner | Initial · extended deadline | Reason for delay and new date |
|---|---|---|---|---|
| | | | | |
| | | | | |

| | |
|---|---|
| **4. Lessons learned: revised documents, training, controls added** | |
| **5. RCCI's assessment: reporting culture, recurring causes, resources** | |
| **6. Decisions requested from the Board** | |

RCCI · date

Chief Executive Officer · date

DRAFT